



Chapter 13 – Security Engineering

Topics covered



- ✧ Security and dependability
- ✧ Security and organizations
- ✧ Security requirements
- ✧ Secure systems design
- ✧ Security testing and assurance

Security engineering



✧ Security engineering

- Tools, techniques and methods to support the development and maintenance of systems that can resist malicious attacks that are intended to damage a computer-based system or its data.

✧ A sub-field of the broader field of **computer security**.

Security dimensions



✧ *Confidentiality*

- Information in a system may be disclosed or made accessible to people or programs that are **not authorized to have access** to that information.

✧ *Integrity*

- Information in a system may be **damaged or corrupted** making it unusual or unreliable.

✧ *Availability*

- **Access to a system** or its data that is normally available may not be possible.

Security levels



- ✧ **Infrastructure security**, which is concerned with maintaining the **security of all systems and networks** that provide an infrastructure and a set of shared services to the organization.
- ✧ **Application security**, which is concerned with the **security of individual application** systems or related groups of systems.
- ✧ **Operational security**, which is concerned with the **secure operation** and use of the organization's systems.

System layers where security may be compromised



Application

Reusable components and libraries

Middleware

Database management

Generic, shared applications (browsers, e--mail, etc)

Operating System

Network

Computer hardware

Application/infrastructure security



✧ Application security

- a **software engineering problem**
- system is designed to resist attacks.

✧ Infrastructure security is

- a **systems management problem**
- infrastructure is configured to resist attacks.

✧ The focus **is application security** rather than infrastructure security.

System security management



✧ User and permission management

- Adding and removing users from the system and setting up appropriate permissions for users

✧ Software deployment and maintenance

- Installing application software and middleware and configuring these systems so that vulnerabilities are avoided.

✧ Attack monitoring, detection and recovery

- Monitoring the system for unauthorized access, design strategies for resisting attacks and develop backup and recovery strategies.

Operational security



- ✧ Primarily a **human and social issue**
- ✧ Ensuring the people do **not take actions that may compromise system security**
 - E.g. Tell others passwords, leave computers logged on
- ✧ Users sometimes take **insecure actions to make it easier for them to do their jobs**
 - a **trade-off between system security and system effectiveness**.



Security and dependability

Security



- ✧ The **security of a system** is a system property that reflects the system's ability to protect itself from accidental or deliberate external attack.
 - Is an essential pre-requisite for availability, reliability and safety.

Security terminology



Term	Definition
Asset	Something of value which has to be protected. The asset may be the <u>software system</u> itself or <u>data</u> used by that system.
Attack	An exploitation of a system's vulnerability . Generally, this is from outside the system and is a deliberate attempt to cause some damage.
Control	A protective measure that reduces a system's vulnerability . <u>Encryption</u> is an example of a control that reduces a vulnerability of a weak access control system
Exposure	Possible loss or harm to a computing system . This can be loss or damage to data, or can be a loss of time and effort if recovery is necessary after a security breach.
Threat	Circumstances that have potential to cause loss or harm . You can think of these as a system vulnerability that is subjected to an attack.
Vulnerability	A weakness in a computer-based system that may be exploited to cause loss or harm.

Threat types



- ✧ **Interception threats** that allow an attacker to **gain access to an asset**.
 - A possible threat to the Mentcare system might be a situation where an attacker **gains access to the records of an individual patient**.
- ✧ **Interruption threats** that allow an attacker to **make part of the system unavailable**.
 - A possible threat might be **a denial of service attack on a system database server** so that database connections become impossible.

Threat types



- ✧ **Modification threats** that allow an attacker to **tamper with a system asset**.
 - In the Mentcare system, a modification threat would be where an attacker **alters or destroys a patient record**.
- ✧ **Fabrication threats** that allow an attacker to **insert false information into a system**.
 - This is perhaps not a credible threat in the Mentcare system but would be a **threat in a banking system, where false transactions might be added to the system that transfer money to the perpetrator's bank account**.

Security assurance



✧ Vulnerability avoidance

- The system is designed so that **vulnerabilities do not occur**.
- For example, if there is **no external network connection** then external attack is impossible

✧ Attack detection and elimination

- The system is designed so that **attacks on vulnerabilities are detected and neutralised** before they result in an exposure.
- For example, **virus checkers find and remove viruses** before they infect a system

✧ Exposure limitation and recovery

- The system is designed so that the **adverse consequences of a successful attack are minimised**.
- For example, a **backup policy allows damaged information to be restored**

Security and dependability



✧ *Security and reliability*

- If a system is attacked and the **system or its data are corrupted** as a consequence of that attack, then this may induce **system failures that compromise the reliability** of the system.

✧ *Security and availability*

- A common attack on a web-based system is **a denial of service attack**, where a web server is flooded with service requests from a range of different sources. The aim of this attack is to **make the system unavailable**.

✧ *Security and resilience*

- **Resilience** is a system characteristic that reflects its **ability to resist and recover from damaging events**.



Security and organizations

Security is a business issue



- ✧ Security is expensive
- ✧ It is important that security decisions are made in a **cost-effective** way
 - There is **no point in spending more than the value of an asset** to keep that asset secure.
- ✧ Organizations use a **risk-based approach** to support security decision making
 - a defined security policy based on security risk analysis
- ✧ **Security risk analysis is a business** rather than a technical process



Security requirements

Security specification



- ✧ Security specification has **something in common with safety requirements specification** – in both cases, the concern is to avoid something bad happening.
- ✧ How do they differ?

Types of security requirement



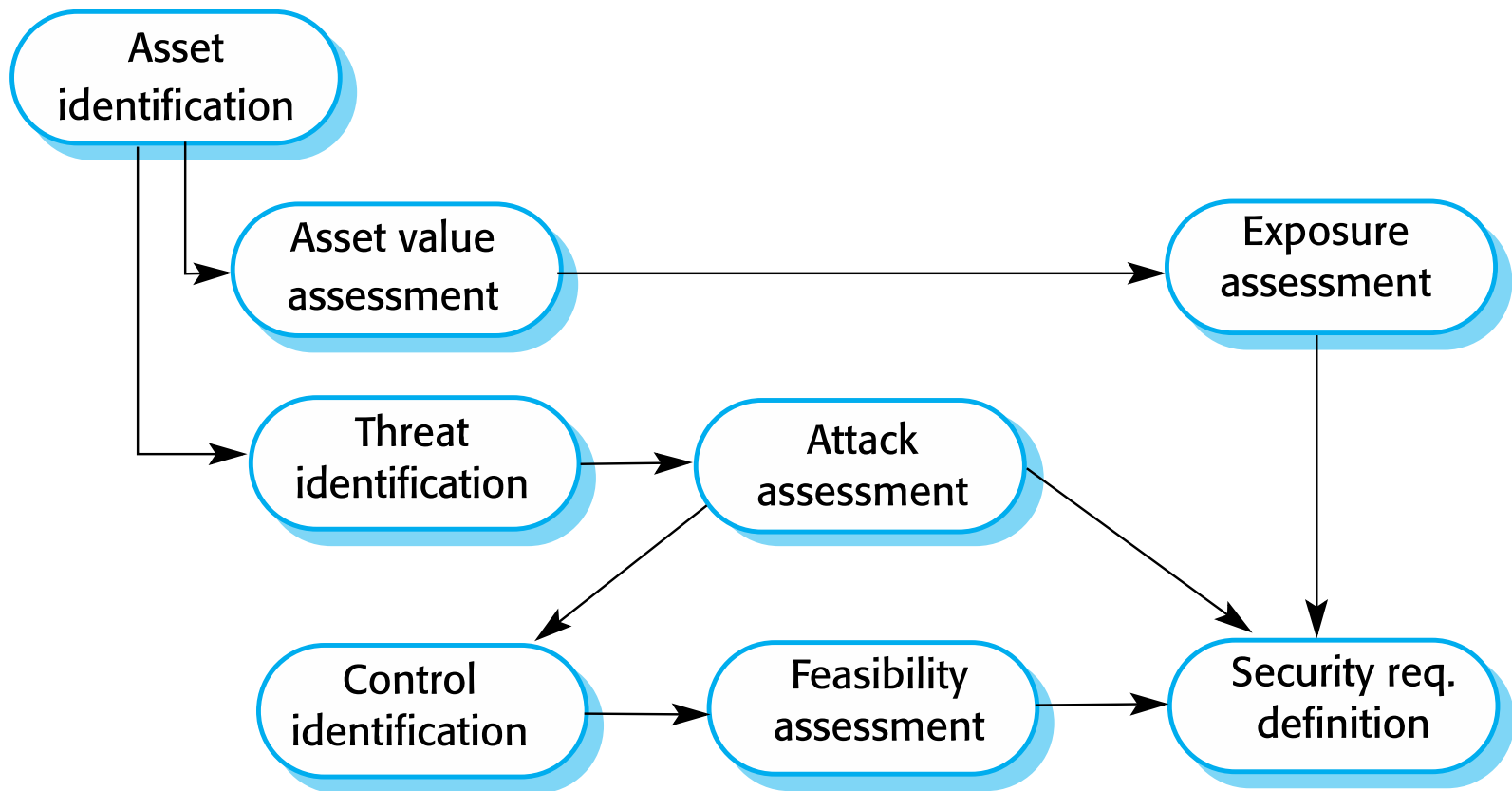
- ✧ Identification requirements.
- ✧ Authentication requirements.
- ✧ Authorisation requirements.
- ✧ Immunity requirements.
- ✧ Integrity requirements.
- ✧ Intrusion detection requirements.
- ✧ Non-repudiation requirements.
- ✧ Privacy requirements.
- ✧ Security auditing requirements.
- ✧ System maintenance security requirements.

Security requirement classification



- ✧ **Risk avoidance requirements** set out the risks that should be avoided by **designing the system so that these risks simply cannot arise.**
- ✧ **Risk detection requirements** define mechanisms that **identify the risk if it arises and neutralise the risk before losses occur.**
- ✧ **Risk mitigation requirements** set out how the system should be **designed so that it can recover from and restore system assets after some loss has occurred.**

The preliminary risk assessment process for security requirements



Security risk assessment



✧ Asset identification

- Identify the key system assets (or services) that have to be protected.

✧ Asset value assessment

- Estimate the value of the identified assets.

✧ Exposure assessment

- Assess the potential losses associated with each asset.

✧ Threat identification

- Identify the most probable threats to the system assets

Security risk assessment



✧ **Attack assessment**

- Decompose threats into possible attacks on the system and the ways that these may occur.

✧ **Control identification**

- Propose the controls that may be put in place to protect an asset.

✧ **Feasibility assessment**

- Assess the technical feasibility and cost of the controls.

✧ **Security requirements definition**

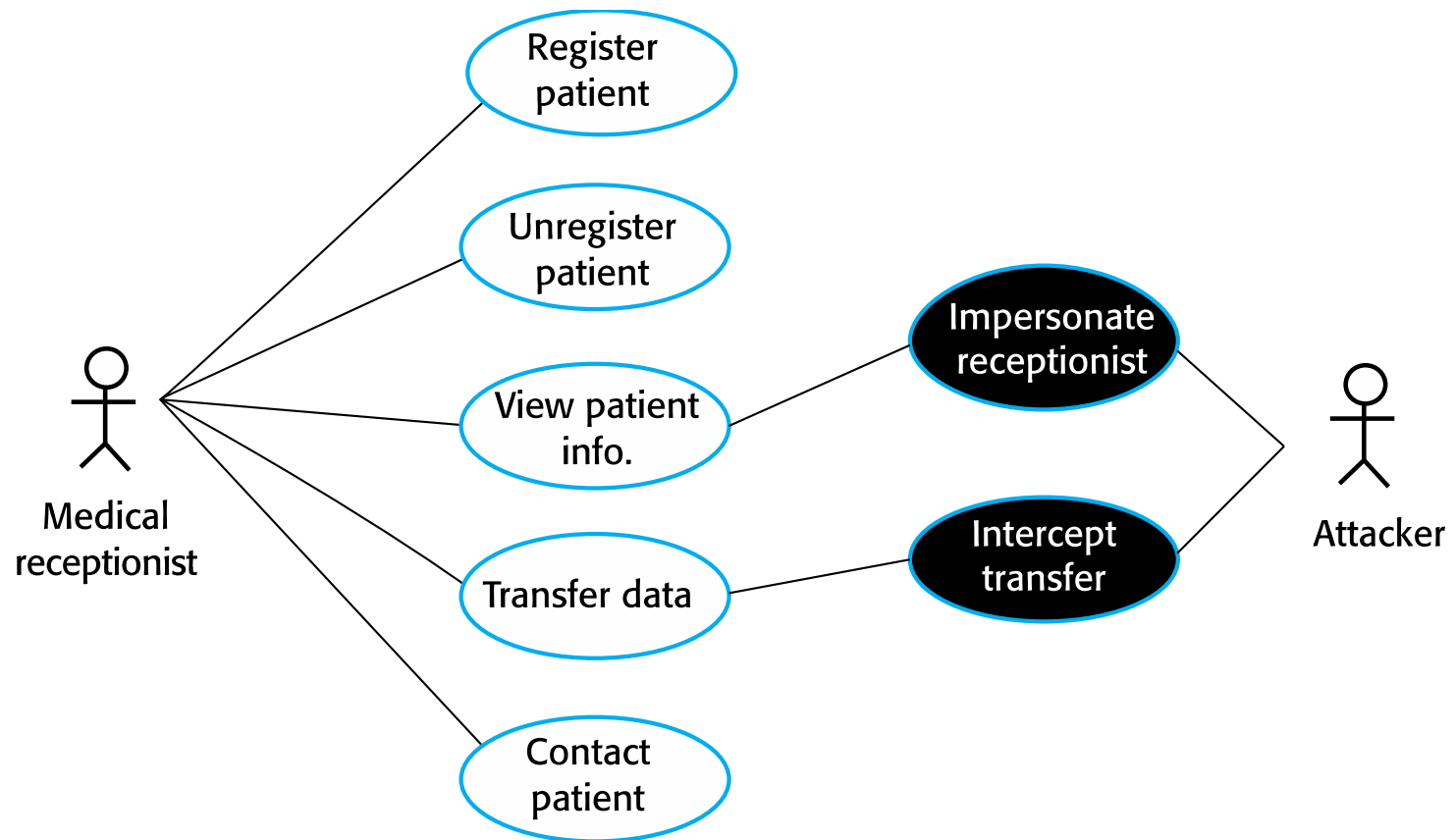
- Define system security requirements. These can be infrastructure or application system requirements.

Misuse cases



- ✧ Misuse cases are instances of threats to a system
- ✧ **Interception threats**
 - Attacker gains access to an asset
- ✧ **Interruption threats**
 - Attacker makes part of a system unavailable
- ✧ **Modification threats**
 - A system asset is tampered with
- ✧ **Fabrication threats**
 - False information is added to a system

Misuse cases



LTD: Mentcare use case – Transfer data



Mentcare system: Transfer data

Actors	Medical receptionist, Patient records system (PRS)
Description	A receptionist may transfer data from the Mentcare system to a general patient record database that is maintained by a health authority. The information transferred may either be updated personal information (address, phone number, etc.) or a summary of the patient's diagnosis and treatment.
Data	Patient's personal information, treatment summary.
Stimulus	User command issued by medical receptionist.
Response	Confirmation that PRS has been updated.
Comments	The receptionist must have appropriate security permissions to access the patient information and the PRS.

LTD: Mentcare misuse case: Intercept transfer



Mentcare system: Intercept transfer (Misuse case)

Actors	Medical receptionist, Patient records system (PRS), Attacker
Description	A receptionist transfers data from his or her PC to the Mentcare system on the server. An attacker intercepts the data transfer and takes a copy of that data.
Data (assets)	Patient's personal information, treatment summary
Attacks	A network monitor is added to the system and packets from the receptionist to the server are intercepted. A spoof server is set up between the receptionist and the database server so that receptionist believes they are interacting with the real system.

LTD: Misuse case: Intercept transfer



Mentcare system: Intercept transfer (Misuse case)

Mitigations	All networking equipment must be maintained in a locked room. Engineers accessing the equipment must be accredited. All data transfers between the client and server must be encrypted. Certificate-based client-server communication must be used
Requirements	All communications between the client and the server must use the Secure Socket Layer (SSL). The https protocol uses certificate based authentication and encryption.

LTD: Organizational security policies – A Case Study (e.g Mentcare system)



- ✧ *The assets that must be protected*
- ✧ *The level of protection that is required for different types of asset*
- ✧ *The responsibilities of individual users, managers and the organization*
- ✧ *Existing security procedures and technologies that should be maintained*
- ✧ *Risk assessment and management*
- ✧ *Risk management involves*

LTD: Mentcare system or any System



- ✧ Asset analysis in a preliminary risk assessment report for the Mentcare system
- ✧ Security requirements for the Mentcare system
- ✧ Protection requirements
- ✧ Design risk assessment



- ✧ *Considering research on the Internet and the unresolved issues on the technical complexity, uncertainty, and fluidity of authenticity, integrity, non-repudiation, and reliability of electronic document in the era of AI (be it text, voice, motion or motionless pictures) in the 21st century, kindly advise a client on the deep current and future technical issues and solutions, if any, on the use of AI applications in creating, curating, and altering electronic documents, whether hacked or lawfully communicated to the receiver or falsely created or curated by someone who wants to tender the document in court?*



- ✧ *Put differently, some of the questions to be addressed technically include, among others:*
- ✧ *1. Can a telecommunication or internet service provider alter, change, edit or falsify the time stamp on it's system at the backend to suit the company such as MTN or anyone MTN wants to fraudulently support?*
- ✧ *2. Technically, what are the standard practice and procedure if an independent forensic investigator is legally saddled with the responsibility of auditing the system of MTN, for example, where there is a contestation on an electronic document?*



- ✧ 3. *Prior to electronic documentation, it was relatively easier to determine the authenticity, reliability and non-repudiability of documents but what can be said of electronic document especially in the era of AI?*
- ✧ 4. *What's the universally tested, and accepted technical standard practice and procedure for the authentication, integrity and non-repudiation of electronic document?*



Secure systems design

Secure systems design



- ✧ **Security should be designed into a system** – it is very difficult to make an insecure system secure after it has been designed or implemented
- ✧ **Architectural design**
 - how do architectural design decisions affect the security of a system?
- ✧ **Good practice**
 - what is accepted good practice when designing secure systems?

Design compromises



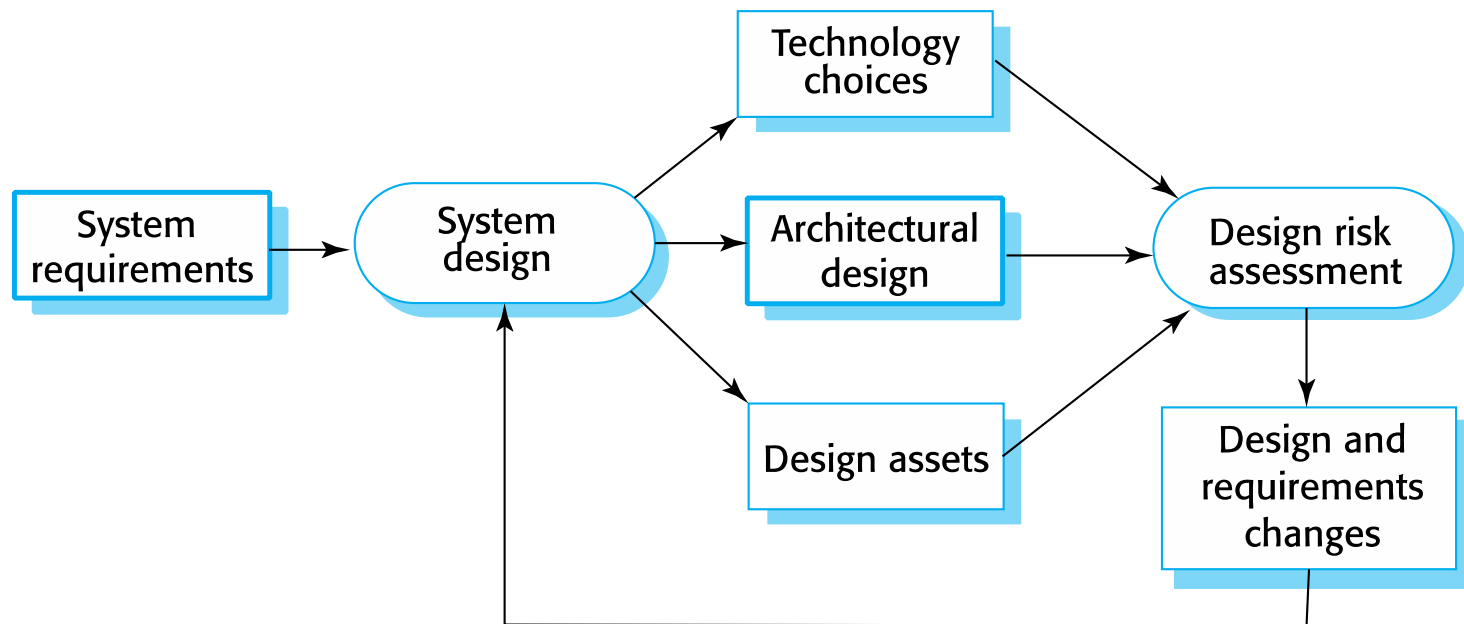
- ✧ Adding security features to a system to enhance its security affects other attributes of the system
- ✧ Performance
 - Additional security checks slow down a system so its response time or throughput may be affected
- ✧ Usability
 - Security measures may require users to remember information or require additional interactions to complete a transaction. T
 - This makes the system less usable and can frustrate system users.

Design risk assessment

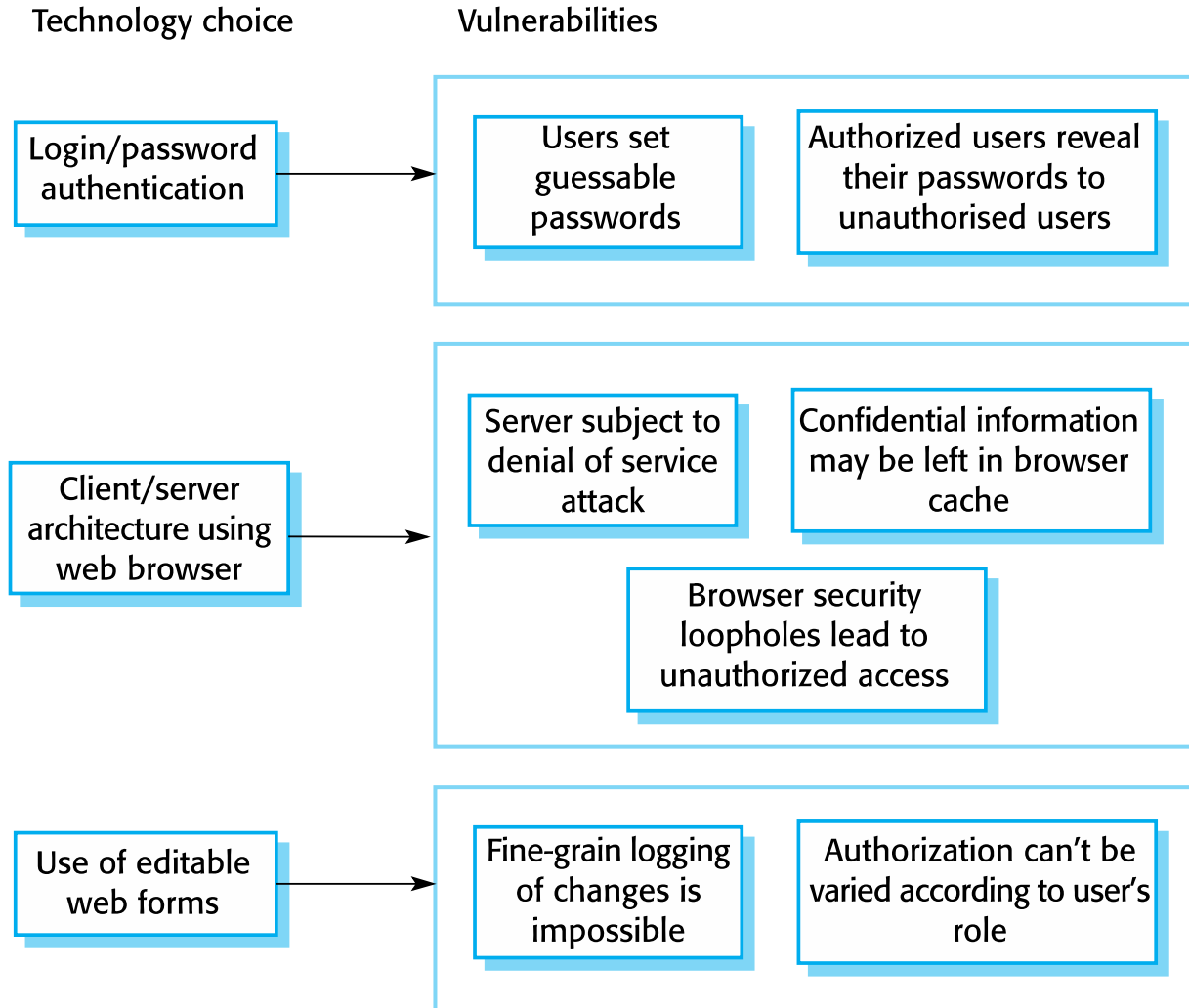


- ✧ **Risk assessment** while the system is being developed and after it has been deployed
- ✧ **Vulnerabilities** that arise from design choices may therefore be identified.

Design and risk assessment



Vulnerabilities associated with technology choices



Security requirements



- ✧ A password checker shall be made available and shall be run daily.
- ✧ Weak passwords shall be reported to system administrators.
- ✧ Access to the system shall only be allowed by approved client computers.
- ✧ All client computers shall have a single, approved web browser installed by system administrators.

Architectural design



✧ **Two fundamental issues** have to be considered when designing an architecture for security.

- **Protection**

- How should the system be organised so that critical assets can be protected against external attack?

- **Distribution**

- How should system assets be distributed so that the effects of a successful attack are minimized?

✧ **These are potentially conflicting**

- If assets are distributed, then they are **more expensive to protect**. If assets are protected, then **usability and performance requirements may be compromised**.

Protection



✧ Platform-level protection

- Top-level **controls on the platform** on which a system runs.

✧ Application-level protection

- Specific protection **mechanisms built into the application** itself
e.g. additional password protection.

✧ Record-level protection

- Protection that is **invoked when access to specific information** is requested

✧ **These lead to a layered protection architecture!**

A layered protection architecture



Platform level protection

System
authentication

System
authorization

File integrity
management

Application level protection

Database
login

Database
authorization

Transaction
management

Database
recovery

Record level protection

Record access
authorization

Record
encryption

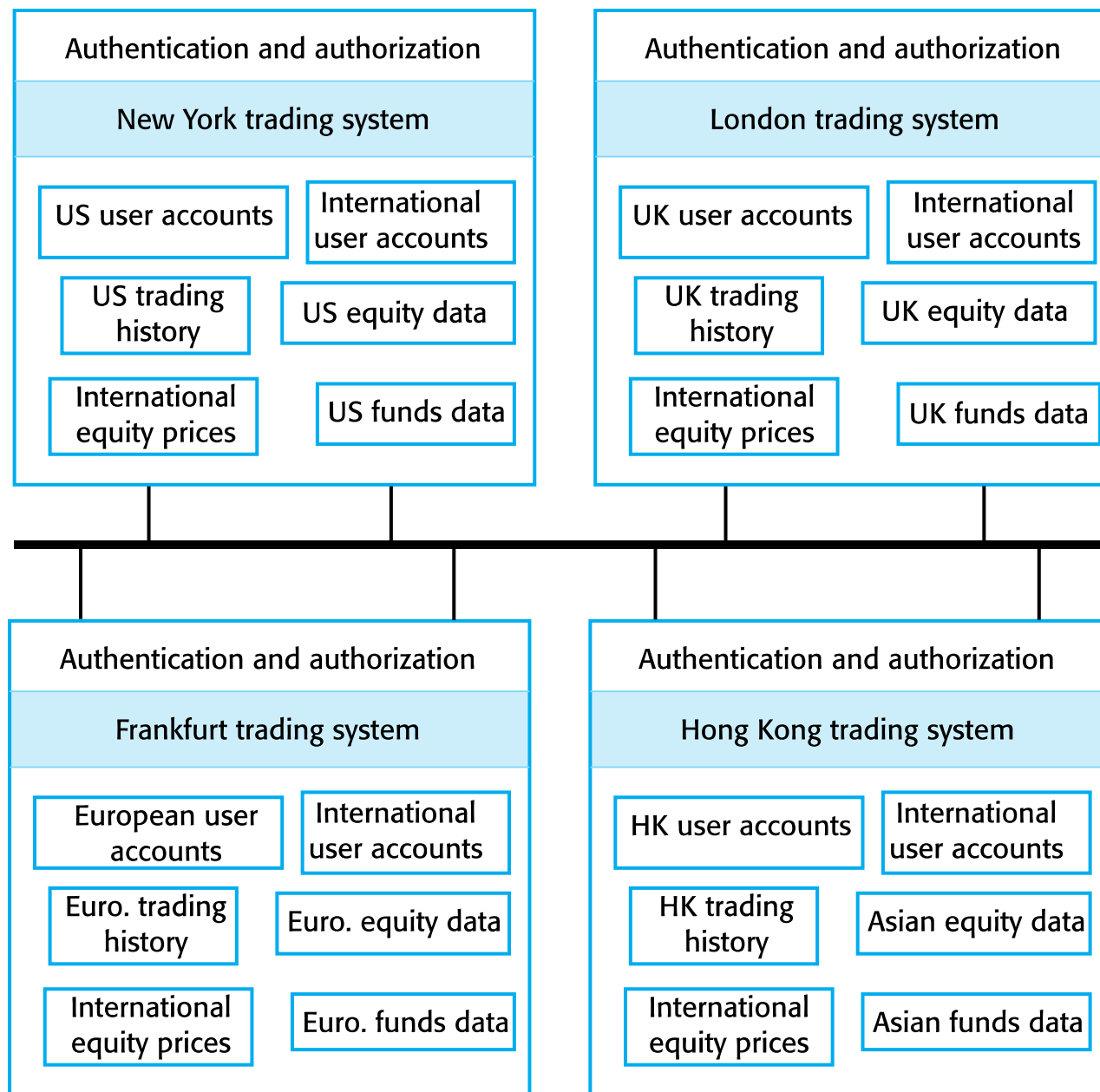
Record integrity
management

Patient records



✧ Distributing assets

- attacks on one system do not necessarily lead to complete loss of system service
- Each platform has separate protection features
- They do not share a common vulnerability
- Important if the risk of denial of service attacks is high



Distributed assets in an equity trading system

Design guidelines for security engineering



- ✧ Design guidelines encapsulate good practice in secure systems design
- ✧ Design guidelines serve two purposes:
 - They raise awareness of security issues in a software engineering team. Security is considered when design decisions are made.
 - They can be used as the basis of a review checklist that is applied during the system validation process.
- ✧ Design guidelines here are applicable during software specification and design

LTD: Design guidelines for secure systems engineering



Security guidelines	
Base security decisions on an explicit security policy	
Avoid a single point of failure	
Fail securely	
Balance security and usability	
Log user actions	
Use redundancy and diversity to reduce risk	
Specify the format of all system inputs	
Compartmentalize your assets	
Design for deployment	
Design for recoverability	

Design guidelines 1-3



✧ Base decisions on an explicit security policy

- Define a security policy for the organization that sets out the fundamental security requirements that should apply to all organizational systems.

✧ Avoid a single point of failure

- Ensure that a security failure can only result when there is more than one failure in security procedures. For example, have password and question-based authentication.

✧ Fail securely

- When systems fail, for whatever reason, ensure that sensitive information cannot be accessed by unauthorized users even although normal security procedures are unavailable.

Design guidelines 4-6



✧ Balance security and usability

- Try to avoid security procedures that make the system difficult to use. Sometimes you have to accept weaker security to make the system more usable.

✧ Log user actions

- Maintain a log of user actions that can be analyzed to discover who did what. If users know about such a log, they are less likely to behave in an irresponsible way.

✧ Use redundancy and diversity to reduce risk

- Keep multiple copies of data and use diverse infrastructure so that an infrastructure vulnerability cannot be the single point of failure.

Design guidelines 7-10



✧ Specify the format of all system inputs

- If input formats are known then you can check that all inputs are within range so that unexpected inputs don't cause problems.

✧ Compartmentalize your assets

- Organize the system so that assets are in separate areas and users only have access to the information that they need rather than all system information.

✧ Design for deployment

- Design the system to avoid deployment problems

✧ Design for recoverability

- Design the system to simplify recoverability after a successful attack.

Aspects of secure systems programming



- ✧ **Vulnerabilities are often language-specific.**
- ✧ Array bound checking is automatic in languages like **Java** so this is not a vulnerability that can be exploited in Java programs.
- ✧ However, **millions of programs are written in C and C++** as these **allow for the development of more efficient software** so
 - simply **avoiding the use of these languages is not a realistic option.**

LTD: Dependable programming guidelines



Dependable programming guidelines

1. **Limit the visibility of information in a program**
2. **Check all inputs for validity**
3. **Provide a handler for all exceptions**
4. **Minimize the use of error-prone constructs**
5. **Provide restart capabilities**
6. **Check array bounds**
7. **Include timeouts when calling external components**
8. **Name all constants that represent real-world values**

LTD: Security testing and assurance



- ✧ What is security testing and assurance?
- ✧ What are problems with security testing?
- ✧ Discuss security validation

LTD: Examples of security terminology (Mentcare)



Term	Example
Asset	The records of each patient that is receiving or has received treatment.
Exposure	Potential financial loss from future patients who do not seek treatment because they do not trust the clinic to maintain their data. Financial loss from legal action by the sports star. Loss of reputation.
Vulnerability	A weak password system which makes it easy for users to set guessable passwords. User ids that are the same as names.
Attack	An impersonation of an authorized user.
Threat	An unauthorized user will gain access to the system by guessing the credentials (login name and password) of an authorized user.
Control	A password checking system that disallows user passwords that are proper names or words that are normally included in a dictionary.

Key points



- ✧ Security engineering is concerned with how to develop systems that can resist malicious attacks
- ✧ Security threats can be threats to confidentiality, integrity or availability of a system or its data
- ✧ Security risk management is concerned with assessing possible losses from attacks and deriving security requirements to minimise losses
- ✧ To specify security requirements, you should identify the assets that are to be protected and define how security techniques and technology should be used to protect these assets.

Key points



- ✧ Key issues when designing a secure systems architecture include organizing the system structure to protect key assets and distributing the system assets to minimize the losses from a successful attack.
- ✧ Security design guidelines sensitize system designers to security issues that they may not have considered. They provide a basis for creating security review checklists.
- ✧ Security validation is difficult because security requirements state what should not happen in a system, rather than what should. Furthermore, system attackers are intelligent and may have more time to probe for weaknesses than is available for security testing.